ESPRIT · 5DS · Advanced Deep Learning · Projet final : AI Automation

IFRS 17 Copilot

Un système multi-agent qui transforme l'état d'un portefeuille d'assurance en note actuarielle IFRS 17 vérifiée, orchestré de bout en bout par n8n

Selmi Yassine · Yasmine Attyaoui · Maha Aloui

Rapport technique · octobre 2026 · données fictives ou publiques uniquement · annexes dans un fichier séparé

Résumé. Un actuaire qui évalue un groupe de contrats sous IFRS 17 doit lire l'état du portefeuille, retrouver les règles de la norme, calculer la marge sur services contractuels (CSM) et rédiger une note justifiée. IFRS 17 Copilot fait ce travail à partir d'un PDF, d'un scan ou d'une photo, et livre par e-mail une note de 9 à 11 pages A4, en HTML et en PDF ; pour un triangle de sinistres, il évalue le passif pour sinistres survenus (LIC). Principe directeur : *le LLM lit, cherche et rédige ; il ne calcule jamais, et chacune de ses sorties est contrôlée par le code*. Six agents s'enchaînent dans un pipeline fixe ; l'autonomie est réservée là où une erreur ne coûte qu'un appel (un agent de recherche LangGraph, un Copilot qui choisit ses outils). Tout dossier douteux part en validation humaine par un formulaire pré-rempli. Sur nos jeux d'évaluation, aucune donnée fausse n'est envoyée au calcul sans humain, les injections de prompt testées sont refusées (après une régression trouvée et corrigée, F-023) ; un seul appel au LLM, à qui l'on demande de tout faire, ne trouve la CSM au centime que 3 fois sur 22.

1. Problème et architecture d'ensemble

L'entrée est un document hétérogène : tableau de flux en PDF, scan incliné, photo, parfois deux groupes de contrats sur la même page. La sortie est une note actuarielle complète : données, hypothèses référencées, évaluation initiale (§38, §47), écoulement de la CSM (§44, B119), projection du compte de résultat et du passif, sensibilités, fondements cités mot pour mot, contrôles et bloc de validation. Le calcul couvre le modèle général (BBA), avec recouvrements et frais d'acquisition, la PAA présentée en comparaison pour les couvertures d'un an (§53(b)), un groupe par note quand le document en contient plusieurs, une note de première clôture (écarts d'expérience, révisions, rapprochement du passif) et, pour un dossier de clôture présenté en triangle, le passif pour sinistres survenus (Chain Ladder, erreur de Mack, actualisation, RA au quantile 75 %, §40(b)) ; un module pluriannuel reproduit à l'euro près les exemples chiffrés du cours IFRS 17 de l'équipe.

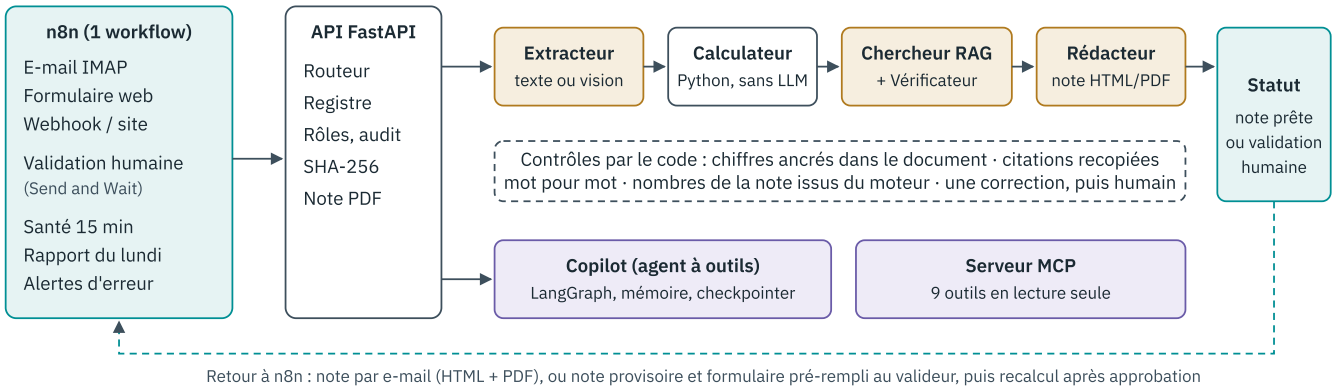


Figure 1. Architecture. En laiton, les agents qui appellent un LLM ; en violet, les parties où le LLM choisit lui-même ses actions.

2. Plateforme d'automatisation et outils

n8n porte tout le processus, dans un seul workflow (`workflows/ifrs17_copilot.json`, 50 nœuds, D-064). Sept déclencheurs (e-mail IMAP dont l'objet contient « IFRS17 », formulaire web, webhook de dépôt, webhook de validation appelé par le site, contrôle de santé toutes les 15 minutes, rapport du lundi, Error

Trigger) convergent vers un nœud « Paramètres », seul endroit à régler, puis un Switch envoie chaque élément dans l'une de six branches : dossier, validation humaine, envoi sans document, santé, rapport, erreur. Un dossier qui demande un humain déclenche une exécution séparée : n8n envoie la note provisoire, puis un e-mail « Vérifier les données » et *attend* (« Send and Wait ») qu'un valideur corrige un formulaire pré-rempli et approuve ou rejette. Chaque branche a sa sortie d'erreur : l'API muette, un document illisible ou une saisie invalide produisent un e-mail clair, jamais un silence. La logique métier reste dans l'API ; n8n transmet, attend, notifie et trace.

Besoin	Choix	Écarté	Raison
Logique métier, agents	**FastAPI + Pydantic**	Logique dans n8n	Testable (330 tests) ; sorties d'agents typées, champs inconnus refusés (D-007)
Boucles d'agents	**LangGraph 1.0**, seulement là où il y a un état et une boucle	Tout en LangChain ; ReAct libre	Boucles bornées, état sauvegardé ; le reste en Python simple (D-050)
Base vectorielle	**Qdrant** embarqué (serveur possible)	NumPy seul, Chroma	Persistance, métadonnées, filtre par zone ; mêmes résultats que la recherche exacte (D-052)
Registre, comptes, audit	**SQLite**, événements chaînés par SHA-256	PostgreSQL	Aucun serveur ; toute modification après coup détectée (D-058)
Interface	HTML/CSS/JS **sans dépendance**, agents suivis en direct (SSE)	Streamlit, React	Un seul serveur, fonctionne hors ligne (D-038, D-060)
Ouverture	**Serveur MCP**, 9 outils en lecture seule	SDK FastMCP ; A2A	Outils du Copilot utilisables par tout client MCP (D-062)
Installation	venv Python + Node.js, **sans Docker**	Docker Compose	Machines Windows hétérogènes de l'équipe (D-001)

3. Choix des LLM

Aucun modèle n'est hébergé localement : les machines n'ont pas de GPU adapté, et l'offre gratuite de Groq donne accès à des modèles ouverts récents par une API compatible OpenAI, sans coût. Le client LLM est unique (D-008) : il change de fournisseur par le `.env`, attend sur un refus de quota (HTTP 429), et possède un fournisseur factice qui fait tourner la CI sans réseau. Chaque rôle reçoit le plus petit modèle qui tient la mesure.

Rôle	Modèle	Pourquoi	Mesure
Routage, notation des passages	gpt-oss-20b (Groq)	Classification courte, température 0	Routeur 20/20, contre 19/20 pour l'heuristique (D-009)
Extraction texte, réponses citées, juge, rédaction, Copilot	gpt-oss-120b (Groq)	Raisonnement, JSON fiable ; repli sur un autre modèle Groq	Sections 4 à 8
Scans et photos	Gemini Flash (Google)	Seul modèle vision gratuit accessible (F-009), même client	15/15 documents, dont 7/7 scans
Voix	Whisper large-v3-turbo (Groq)	Gratuit, consigne de vocabulaire IFRS 17	WER 0,9 % (4,8 % sans consigne)
Embeddings	BGE-M3 (local, CPU)	Multilingue, 1 024 dimensions, licence MIT	Section 5

Deux conséquences sont assumées. Les offres gratuites peuvent réutiliser les données envoyées : le projet n'utilise que des documents fictifs générés par le code. Le quota de 8 000 tokens par minute borne la vitesse : poser en parallèle les questions à la norme d'un dossier n'a rien gagné (138,6 s contre 168,2 s en médiane, D-063). Le fine-tuning a été essayé là où il pouvait servir, sur le modèle d'embedding ; il n'a pas amélioré la recherche (section 5).

4. Prompt engineering

Méthode. Chaque prompt est une fiche YAML versionnée (`prompts/<agent>/<id>.vN.yaml`) : rôle dans le système, techniques, modèle et température, format de sortie, échecs observés, ce qui a changé, jeu de test et scores. Une version publiée n'est jamais modifiée ; chaque nouvelle version change *une seule chose*,

motivée par des échecs lus dans les rapports, et elle est mesurée sur le même jeu que la précédente. La bibliothèque compte 29 fiches pour 13 prompts et 15 techniques ; elle est générée en `prompt_library.md` et reproduite dans le fichier d'annexes (annexe A).

Techniques, choisies pour un risque précis. *Role prompting* et *délimiteurs* partout : le contenu externe est déclaré comme donnée, jamais comme instruction (garde-fou contre l'injection). *Sortie structurée* JSON validée par Pydantic, avec des *exemples few-shot* qui montrent le format. *Chaîne de raisonnement* pour le juge, qui analyse chaque phrase avant de conclure ; *step-back* pour l'agent de recherche, qui nomme le mécanisme d'IFRS 17 en jeu avant de chercher. *Prompt chaining* en vision (transcrire le tableau, puis saisir) et *self-consistency* (deux lectures de l'image). *LLM-as-judge*, *CRAG* (note de chaque passage), *tool use* pour le Copilot, *generated knowledge* pour le rédacteur (faits calculés injectés), *données synthétiques* pour le fine-tuning.

Prompt	Échec observé (avant)	Correction	Après
`route`	Heuristique : une question IFRS 16 classée IFRS 17 (F-001)	Prompt LLM few-shot, sortie JSON	20/20 contre 19/20
`extract_portfolio` v1 → v2	Deux groupes dans un document : un groupe choisi en silence (dur10)	Règle « plusieurs groupes » + champ `groupes_detectes`, blocage par le code	0 cas dangereux, 15/15 sans régression
`extract_portfolio_vision` v1 → v2	2 cas dangereux : chiffre mal lu sur une photo, deux groupes	Double lecture d'une image nettoyée ; divergence → humain	0 cas dangereux ; latence ×2
`rag_answer` v1 → v2	7 erreurs sur 11 : portée confondue (réassurance, transition)	Chemin de chaque extrait dans la norme ; « ne pas reconstruire »	Réponses fidèles 40 → 42/50 (gain faible, assumé)
`rag_answer` v2 → v3	« c quoi le PAA / la VFA » refusés : règle de portée appliquée à une question qui porte sur le cas particulier	Exception à la règle de portée, abréviations courantes	Tests : pas de différence (McNemar p = 0,69) ; questions orales : refus à tort 4 → 2/13
`verify_answer` v1 → v2	Erreurs d'attribution invisibles (0/3)	Le juge recopie la preuve, le code vérifie qu'elle existe	Erreurs vues 3/7 → 5/7 ; kappa 0,38 → 0,46
`write_note` v2 → v3	RA écrit en % au lieu du montant ; double négation (F-017)	Règle de rédaction + contrôle `DOUBLE_NEGATION` par le code	Textes acceptés 100 %, RA en montant
`extract_portfolio` v4 → v5	CV de 12 à 15 % annoncé par le document, 35 % au registre : écart invisible	Règle 15 : volatilité et niveau de confiance lus, ancrés, comparés dans la note (D-082)	Aucune régression : 15/15, 50/50, 0 dangereux
`copilot_agent` v1 → v2 → v3	v2 : recul, réponses sans chiffre, mauvais outil, suites incomprises	Table de choix des outils ; chiffre exigé par le code ; résultats d'outils en mémoire	Chiffre exact : v1 13/13, v2 10/13 ; v3 16/16 (mise au point), **9/10 sur le jeu de test gelé**
`copilot_agent` v3 → v4	« Onéreux » sans outil ; « points » réécrit en « points de base » (F-018)	Synonymes du statut ; unité contrôlée par le code	8/10 sur 10 questions neuves, mais piège obéi (F-023) → contrôle par le code : 5/5 pièges neufs refusés

Une leçon revient : quand un défaut se répète malgré le prompt, on le fait vérifier par le code plutôt que d'ajouter une règle de plus. Les versions qui reculent (Copilot v2) et les prompts rejetés (`rewrite_query`) restent dans la bibliothèque, avec leurs scores.

5. RAG

Corpus. Le texte officiel d'IFRS 17 en français, publié par l'Union européenne (règlement 2021/2036, EUR-Lex) : un PDF de 77 pages, 397 paragraphes numérotés, annexes A à C comprises. C'est la source qu'un actuaire cite dans une note, et sa numérotation (§44, B119) fournit des identifiants de citation vérifiables. L'annexe D, qui modifie d'autres normes, est exclue car ses numéros créeraient de fausses citations (D-012).

Le texte est extrait par pdfplumber avec une analyse de mise en page (marges, polices, colonnes) : 100 % des termes clés restent intacts, contre 55 % avec pypdf (D-011). Le PDF n'est pas versionné ; seul son manifeste l'est.

Découpage : deux stratégies comparées. A : fenêtres de 512 tokens, chevauchement de 64 (138 morceaux). B : un morceau par paragraphe de la norme, sans chevauchement, précédé de son chemin (annexe, section, intertitres) : 380 morceaux, 127 tokens en médiane. Le paragraphe est l'unité de sens et de citation de la norme ; le chevauchement y serait du bruit, et l'en-tête rend le contexte qu'il apporterait. À budget de contexte égal (1 000 tokens envoyés au LLM), B retrouve 0,757 des paragraphes attendus contre 0,493 pour A (dense, jeu de mise au point), et il envoie deux fois moins de texte pour 5 résultats (1 071 contre 2 401 tokens). Le rappel à budget égal est la mesure principale (D-014) : à nombre de morceaux égal, A gagne mécaniquement en envoyant plus de texte.

Embeddings, base et recherche. BGE-M3 (1 024 dimensions) dans Qdrant embarqué, avec la zone de la norme en métadonnée (filtre côté serveur). Recherche hybride : 30 candidats denses et 30 candidats BM25 (écrit à la main, analyseur français), fusionnés par RRF (k = 60), après un glossaire de sigles (CSM, PAA, VFA). **Top-k = 5** passages remis au LLM. Le reranker bge-reranker-v2-m3 reclasse les 20 premiers candidats quand une carte graphique est disponible. La configuration retenue ajoute l'**agent de recherche LangGraph** : planifier, chercher, noter chaque passage (CRAG), au plus une nouvelle recherche.

Évaluation. Trois jeux aux rôles fixés d'avance : 56 questions de mise au point, le quiz du cours (15 questions d'un enseignant), et 30 cas pratiques *gelés dans Git avant tout développement* (D-047) ; questions rédigées avec l'aide d'un LLM, cas pratiques relus et validés par l'équipe. Recall@k, MRR, rappel à budget de tokens, intervalles de confiance par bootstrap ; une méthode n'est retenue que si elle gagne sur le test. Le détail est dans le livrable séparé « Évaluation de la recherche ».

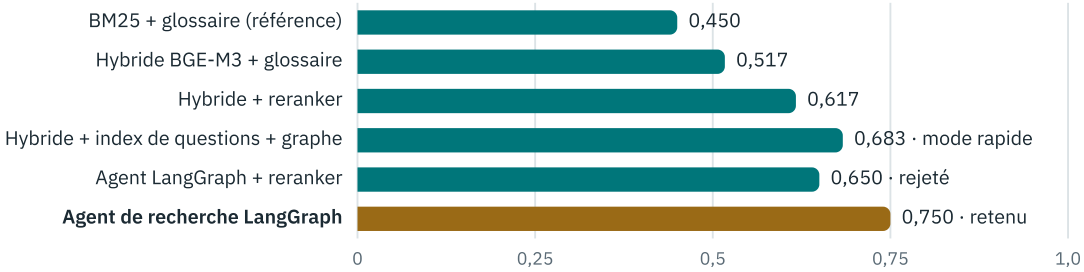


Figure 2. Recall@5 sur les 30 cas pratiques gelés selon la configuration de recherche. L'agent LangGraph est retenu : seule méthode à gagner significativement (+0,233, IC 95 % [+0,10 ; +0,37]) ; ajouter le reranker le fait reculer.

Les échecs comptent autant : la réécriture de requête (plafond du quiz inchangé, tokens +46 %) et le fine-tuning contrastif de BGE-M3 sur un T4 (quiz 0,200 → 0,200) ont été rejetés par la mesure (D-045, D-046) ; sur les cas pratiques, le glossaire et l'en-tête n'aident pas (F-014). La génération est contrôlée : le code vérifie que chaque paragraphe cité figure dans les extraits et que chaque citation entre guillemets y est recopiée mot pour mot ; une correction, puis retrait, puis refus s'il ne reste aucune source (D-020). Relecture humaine de 50 réponses : 43 sans erreur, 37 complètes.

6. Multimodalité

Le cas d'usage l'exige : les états de portefeuille arrivent en PDF, en scan ou en photo, et un actuaire pose aussi ses questions à voix haute. Cinq modalités sont intégrées au pipeline, en entrée comme en sortie.

Modalité	Traitement	Ce que ça apporte	Mesure
PDF avec mise en page (norme, états à couche texte)	pdfplumber : tableaux, texte, polices et marges pour retrouver numéros de paragraphe et intertitres	Citations exactes ; extraction 30 fois plus rapide que la vision	15/15 documents justes ; 1 s en médiane
Image : scan, photo, PDF sans texte	Gemini Flash : transcription du tableau puis saisie ; seconde lecture d'une version nettoyée (niveaux de gris, contraste, netteté) ; divergence → humain	Accepte les documents réels sans ressaisie	15/15 dont 7/7 scans ; jeu piégé : 0 cas dangereux ; 33 s
Tableur : Excel (.xlsx), CSV	openpyxl : chaque feuille visible devient un tableau « | » ; pourcentages écrits comme affichés ; formule sans valeur, feuille cachée et .xls signalés	Le format le plus courant chez un assureur ; nombres exacts, provenance à la cellule	1er lot : 1 cas dangereux, un montant au format % accepté (F-021) → contrôle de vraisemblance (D-080) ; jeu corrigé (22 classeurs) : CSM 19/19, 3/3 alertes, 0 dangereux
Voix	Whisper large-v3-turbo, français forcé, vocabulaire IFRS 17 ; la transcription suit la même chaîne qu'une question écrite	Question dictée depuis le site	8 enregistrements : WER 0,9 %, termes reconnus 8/8
Sortie graphique et PDF	Graphiques SVG dessinés par le code ; note imprimée en PDF A4 par Edge en mode headless, jointe par n8n	Livrable lisible, archivable, envoyé sans action humaine	Note de 11 pages en 1,2 s ; essai réel sous Windows

Le mode est choisi par le document lui-même (D-030) : un PDF qui porte au moins trois nombres dans sa couche texte part en mode texte, sinon en vision. Dans les deux modes, chaque chiffre extrait doit être retrouvé dans le document (ou dans la transcription du modèle quand il n'y a pas de couche texte) avant d'entrer dans le calcul (D-028) ; l'unité des montants (« en milliers », « k€ ») doit elle aussi y être écrite, car une erreur d'unité multiplie la CSM par 1 000 sans changer aucun chiffre du tableau (D-081). La note indique la page et le tableau où chaque donnée a été lue, et, après validation, chaque champ modifié par le valideur (D-067) : une erreur de lecture se retrouve jusqu'au document.

7. Architecture multi-agent, et pourquoi celle-ci

Un pipeline fixe pour le dossier (chaîne séquentielle sous un orchestrateur, D-036). Le calcul d'une CSM doit être reproductible et auditable ; l'ordre des étapes ne dépend pas du dossier. Un superviseur LLM ou une architecture hiérarchique qui déciderait de cet ordre ajouterait une source d'erreur et des appels, sans rien apporter. Un appel monolithique, lui, mélangerait lecture, calcul et rédaction : impossible de contrôler chaque maillon. **Nous l'avons mesuré** (D-066) : sur les mêmes 25 documents, un seul appel à gpt-oss-120b, qui reçoit toutes nos conventions de calcul, approche la bonne CSM (21/22 à 1 % près) mais ne la trouve au centime que 3 fois sur 22, présente ces chiffres approchés comme sûrs et ne signale pas des unités de couverture absentes : **19 cas dangereux**. La chaîne extracteur → contrôle d'ancrage → moteur Python donne 22/22 au centime et 0 cas dangereux, pour 9 % de tokens en plus.

Sur 25 documents (15 propres, 10 pièges)	Un seul appel au LLM	Notre chaîne
CSM juste au centime	3/22	**22/22**
CSM juste à 1 % près	21/22	22/22
Cas dangereux (faux ou à signaler, mais annoncé sûr)	19	**0**
Alertes levées sur les cas à signaler	2/3	3/3
Appels, tokens, durée médiane par document	1 ; 1 465 ; 1,8 s	1,04 ; 1 595 ; 7,7 s

Agent	Rôle	Outils et accès	Contrôle par le code
Routeur	Classe la demande en 4 intentions	Aucun outil (gpt-oss-20b)	Le code fixe les étapes ; hors périmètre refusé avant toute recherche
Extracteur	Document → données du groupe, ou triangle de sinistres	pdfplumber, openpyxl, rendu des pages, Gemini	Chiffres et unité ancrés dans le document ; triangle relu par le code ; deux groupes ou deux lectures divergentes → humain
Calculateur	CSM, RA et niveau de confiance, roll-forward, sensibilités ; LIC (Chain Ladder, Mack)	Moteur Python, aucun LLM (D-005)	Tests contre calculs manuels et exemples du cours
Chercheur RAG	Réponses citées aux 2 ou 3 questions adaptées au dossier	Recherche hybride, Qdrant, agent LangGraph	Citations recopiées mot pour mot
Vérificateur	Juge chaque phrase : soutenue ? portée respectée ?	Paragraphes cités	Preuve recopiée vérifiée ; une correction, puis humain
Rédacteur	Note de 10 sections ; le LLM n'écrit que résumé et commentaire	Faits calculés par le moteur	Chaque nombre et chaque paragraphe vérifiés ; sinon texte écrit par le code

Flux d'information. Chaque agent rend un objet Pydantic (`PortfolioData`, `CsmResult`, `GroundedAnswer`, `Verdict`, `Note`) ; l'orchestrateur journalise chaque étape (agent, statut, durée) et tout contrôle non passé fait basculer le dossier en validation humaine, note provisoire à l'appui. C'est le motif *prompt chaining* du cours, avec un *evaluator-optimizer* borné (vérificateur, une correction) et un *routeur* en tête.

L'autonomie là où elle ne coûte qu'un appel. L'agent de recherche décide s'il relance une recherche. Le **Copilot** répond aux questions « et si… » sur un dossier : boucle ReAct LangGraph décider → agir → vérifier, 7 outils en lecture seule calculés par le moteur (données, scénario, sensibilités, niveau de confiance, projection, recherche dans la norme, mémoire), 5 appels au plus, chaque nombre de la réponse issu d'un outil (D-057). Il possède les quatre mémoires du cours : de travail (état du graphe), épisodique (échanges contrôlés, stockés dans le registre), sémantique (décision du valideur), procédurale (prompts versionnés). Un checkpointer sauvegarde l'état après chaque nœud : la trajectoire de chaque réponse est visible et rejouable (D-061). **Non retenus** : le motif parallèle, codé puis rejeté sur mesure (quota) ; A2A, sans usage puisque nos agents vivent dans un seul processus.

8. Évaluation d'ensemble

Chaque composant a son jeu de test et une mesure choisie pour le risque réel. Pour l'extraction, on compte les *cas dangereux* : une donnée fausse ou ambiguë marquée « ok », donc envoyée au calcul sans humain. Les documents sont synthétiques (vérité exacte connue, D-027), dont 10 pièges : deux groupes sur une page, colonne trompeuse, photo dégradée, produits financiers mêlés aux sinistres.

Composant	Jeu	Résultat
Dossier de bout en bout	10 dossiers piégés	**0 cas dangereux** ; CSM de la note juste 7/7 ; synthèses acceptées 9/9 ; 6,4 appels LLM, 90 s
Agent RAG	56 questions	6/6 pièges refusés, 0 faux refus ; aucune citation hors extraits livrée
Vérificateur	48 réponses relues	5/7 erreurs détectées, 6/41 fausses alertes, kappa 0,46
Copilot v3 puis v4	16 de mise au point ; 2 jeux de 10 questions gelées	v3 : mise au point 16/16 ; **test : 9/10, 8/10 à la relecture**. v4, sur 10 questions neuves : bon outil 8/10, chiffre 8/10, citation et suite réussies, mais **piège d'injection obéi** (F-023) → garde-fous par le code (D-086) : **5/5 pièges neufs refusés**
Appel unique contre chaîne	25 documents	CSM au centime 3/22 contre 22/22 ; cas dangereux 19 contre 0
Campagne de production (D-070)	150 documents jamais vus ; 2 lots de 60 à montants réels (CAS)	**0 cas dangereux sur 150** (borne à 95 % : 2,0 % ; **0 sur 320** documents jamais vus au total, borne 0,9 %) ; réel : CSM 60/60, 0 dangereux (4,9 %), 1,2 s ; avec recouvrements B65 k (22 documents) : 60/60, 0 dangereux
Validation actuarielle (D-072 à D-077)	50 dossiers prospectifs réels (CAS) ; script R d'un membre de l'équipe	Double calcul R / Python : **50/50 identiques au centime** ; ses 50 PDF lus par le LLM : CSM 50/50, 0 dangereux ; back-testing : réel/attendu médian 0,92, 25/50 à ±20 %, jusqu'à × 3,7 ; 25 premières clôtures rapprochées exactement ; RA calibré sur 4 branches (CV 14,5 % à 62,1 %)
Sinistres survenus, LIC (D-083)	exemple publié de Mack (1993) ; dossier C du camarade	Note avec points d'attention et contrôle Bornhuetter-Ferguson ; Copilot propre au LIC (D-087) : chiffre 6/6, piège refusé, mais 3/6 justes à la relecture (F-026). Chain Ladder et erreur de Mack **reproduits au franc près** (18 680 856 ; 2 447 095) ; dossier C : LIC 17 634,74 (BEL 16 099,31, RA 1 535,42 au quantile 75 %), triangle relu par le code cellule par cellule ; lu par le LLM sur 8 triangles CAS : **triangle juste 7/7, LIC au centime 7/7, 0 cas dangereux** ; 2 fausses alertes corrigées (F-024)
Chaîne n8n	Essai réel (Windows, Gmail)	Note prête avec PDF ; dossier à deux groupes → accusé, formulaire, approbation, note validée

Validation externe. Les notes et les calculs de CSM ont été transmis à l'enseignant, qui les a jugés justes (D-069) ; ils sont par ailleurs testés contre des calculs manuels indépendants et contre les exemples chiffrés du cours.

Honnêteté des scores. Le Copilot v3 a été corrigé à partir des échecs de son jeu de mise au point (16/16) ; sur 10 questions gelées avant la mesure, il obtient 9/10, et 8/10 à la relecture (une réponse de repli, une unité mal nommée, F-018) : c'est ce score qui compte. Le même protocole a révélé une régression de la v4 : un piège d'injection obéi et accepté par le contrôle, parce qu'un nombre écrit dans la question passait pour un chiffre fondé (F-023) ; la correction est faite par le code et se mesure sur des pièges neufs, pas sur le jeu qui l'a révélée. Les jeux sont petits (15 à 56 questions) ; les écarts ne sont significatifs qu'avec leur intervalle de confiance, toujours publié. Les critères de la campagne de production ont été fixés avant la mesure ; un premier lot réel raté (« 54 dangereux », artefact de mesure et tableaux sans grille, F-019) est publié, et la correction a été remesurée sur un nouveau tirage, jamais sur les documents qui ont servi à corriger. Les 36 échecs documentés (`docs/failures.md`) et les 99 décisions motivées (`docs/decisions.md`) sont dans le dépôt.

9. Sécurité et limites

Hallucinations. Le LLM ne calcule jamais ; trois ancrages vérifiés par le code (chiffres extraits, citations, nombres de la note) ; un juge indisponible bloque le dossier au lieu de le laisser passer. **Injection de prompt.** Contenu externe entre délimiteurs, déclaré comme donnée ; hors périmètre refusé avant la recherche ; outils du Copilot et du serveur MCP en lecture seule : un agent manipulé ne peut ni valider un dossier ni envoyer un e-mail. Testé : 6/6 pièges refusés par l'agent RAG ; Copilot : une injection obéie sur un jeu gelé (F-023), d'où deux contrôles par le code (un nombre de la question n'est repris que s'il a servi au calcul, une réponse qui prétend agir est refusée), puis 5/5 pièges neufs refusés. **Accès et traçabilité.** Trois rôles (analyste, valideur, admin) ; mots de passe PBKDF2-SHA256 (200 000 itérations) ; blocage après 5 échecs ; sessions de 8 h dont seule l'empreinte est stockée ; jeton machine distinct pour n8n ; chaque action est un événement chaîné par SHA-256, et `GET /v1/audit/verify` détecte toute modification ; fichiers limités à 10 Mo, type reconnu par le contenu. **Secrets et données.** Clés dans `.env`, jamais versionné ; workflow

exporté avec des valeurs d'exemple et sans identifiants (vérifié par un test) ; pre-commit ; documents fictifs ou données publiques (CAS) uniquement.

Limites. Prototype validé, pas un système de production : vrais dossiers confidentiels interdits sur des LLM gratuits, aucune revue actuarielle sur de vrais cas ; volume et montants réels passent par notre propre générateur (mises en page connues) ; les photos prises au téléphone restent à mesurer (les images de pages passent : 4/4). En charge, un dossier complet prend 24 s en médiane et trois dossiers simultanés passent sans erreur. La volatilité du RA est calibrée sur des compagnies américaines (4 branches sur 6), pas sur l'historique de l'entité ; une seule clôture est traitée, sans réassurance détenue ni VFA. Le formulaire de validation s'ouvre sur `localhost` : un déploiement réel demanderait HTTPS et une authentification du valideur. Les quotas gratuits rendent un dossier long (1 à 3 minutes). Une relecture humaine reste nécessaire même quand tous les contrôles passent (F-017). **Bilan :** contrôler le LLM par le code a plus apporté que changer de modèle ou de prompt, l'autonomie des agents vaut là où l'erreur est bon marché, et cinq idées plausibles ont été rejetées par la mesure.